

Практическая работа № 6

Тема: разработка и оценка защищенности MVP-продукта в соответствии с принципами Secure SDLC и OWASP Top 10.

Цель: сформировать у магистрантов практические навыки проектирования, реализации, тестирования и аудита защищенного программного продукта.

Задание 1.

1. По выбранному варианту требуется доработать до финальной версии минимально жизнеспособный программный продукт (MVP), представляющий собой завершенную прикладную систему с пользовательским интерфейсом и реализованным основным функционалом. Система должна поддерживать ключевой бизнес-процесс варианта, содержать серверный компонент, подсистему хранения данных, механизмы аутентификации и разграничения прав доступа, а также обеспечивать регистрацию критичных событий безопасности и действий пользователей.

Минимальные требования к продукту:

- пользовательский интерфейс для работы с системой;
- не менее 5 API-эндпоинтов или эквивалентных функций;
- не менее 3 сущностей в базе данных (от 200 строк данных в таблицах);
- не менее 2 ролей пользователей;
- полностью реализованный основной функциональный сценарий по варианту;
- проверка входных данных;
- защита паролей в виде хеша;
- разграничение прав доступа;
- журналирование критичных действий без утечки чувствительных данных.

2. Требования по безопасности:

В рамках анализа защищенности разработанный продукт должен быть проверен на наличие уязвимостей и архитектурных недостатков, соответствующих основным классам рисков OWASP Top 10, включая нарушения контроля доступа, ошибки аутентификации, инъекционные атаки, небезопасную конфигурацию, недостатки криптографической защиты, риски цепочки поставок программного обеспечения, нарушения целостности данных и программных компонентов, ошибки журналирования и мониторинга, а также некорректную обработку исключительных ситуаций.

- Broken Access Control -Нарушение контроля доступа
- Security Misconfiguration -Небезопасная конфигурация системы
- Software Supply Chain Failures - Уязвимости цепочки поставок программного обеспечения
- Cryptographic Failures -Ошибки криптографической защиты данных
- Injection - Инъекционные атаки (SQL, OS, LDAP и др.)
- Insecure Design - Небезопасное проектирование системы
- Authentication Failures - Ошибки аутентификации пользователей
- Software or Data Integrity Failures -Нарушение целостности программного обеспечения или данных
- Security Logging and Alerting Failures - Недостатки журналирования и мониторинга безопасности
- Mishandling of Exceptional Conditions - Некорректная обработка исключительных ситуаций и ошибок

Выявить уязвимости, дефекты проектирования и небезопасные практики реализации.

Для каждой найденной проблемы указать (в таблице):

- категорию риска;
- место обнаружения;
- описание уязвимости;

- возможные последствия эксплуатации;
- уровень критичности;
- способ исправления.

Внести исправления в код и конфигурацию системы. Выполнить повторное тестирование и подтвердить устранение выявленных рисков.

3. Разработанный проект должен быть размещен в репозитории GitHub с полной историей изменений. Репозиторий должен содержать исходный код, файл README.md с описанием проекта, инструкцию по установке и запуску, перечень используемых технологий, сведения о реализованных механизмах безопасности, а также результаты тестирования и анализа уязвимостей.
4. Все секреты, ключи, токены и параметры подключения должны храниться вне исходного кода, с использованием переменных окружения или файла конфигурации .env, исключенного из репозитория.
5. Журналирование должно охватывать вход в систему, неуспешные попытки доступа, изменение критичных сущностей, операции изменения прав и иные события, значимые с точки зрения безопасности.
6. Для максимальной оценки проект рекомендуется оформить с использованием Docker / Docker Compose для воспроизводимого развертывания системы.

В отчете задания 1 должны быть представлены:

- тема, цель работы, вариант;
- краткое описание разработанного MVP;
- архитектура системы;
- описание ролей пользователей и разграничения доступа;
- описание основного бизнес-сценария;
- перечень реализованных механизмов безопасности;
- результаты анализа по OWASP Top 10;
- таблица выявленных уязвимостей и мер по их устранению;
- результаты повторного тестирования;
- выводы по работе.

Задание 2. Разработка AI-ассистированной версии продукта и анализ защищенности данных.

С использованием современных бесплатных фреймворков и инструментов искусственного интеллекта требуется разработать альтернативную версию программного продукта, функционально эквивалентную MVP из задания 1. Система должна реализовывать тот же бизнес-сценарий, включать пользовательский интерфейс, серверную часть, базу данных, механизмы аутентификации и авторизации.

В процессе разработки необходимо зафиксировать, какие AI-инструменты, модели и запросы использовались при создании архитектуры, кода и механизмов защиты.

После завершения разработки требуется выполнить анализ защищенности продукта по **OWASP Top 10**, выявить потенциальные уязвимости, указать их категорию, уровень критичности, возможные последствия и предложенные меры устранения.

В отчете задания 2 должны быть представлены данные, как и в отчете 1 задания.

По итогам работы необходимо провести сравнительный анализ решений, разработанных в заданиях 1 и 2, и сделать вывод о влиянии AI-ассистированной разработки на безопасность программного продукта по критериями сравнения минимум 10 (таблица).

Итоговая шкала оценивания:

Задание 1 (максимально 75 баллов).

Задание 2 (Максимально 25 баллов).